

CONFIDENTIAL - INTERNAL USE ONLY

Security Audit Remediation Report

Complaint Management System (CMS)

DOCUMENT VERSION	v1.0 - Final
DATE	17 June 2026
CLASSIFICATION	Confidential
TOTAL FINDINGS	8 - All Resolved

1. Executive Summary

This report documents the complete remediation of 8 security vulnerabilities identified during the security audit of the Complaint Management System (CMS). All 8 vulnerabilities have been successfully fixed and verified through middleware enhancements, input validation, Subresource Integrity (SRI) implementation, and security header configuration.

Overall Status: All 8 findings have been resolved. The application now meets the security requirements outlined in the audit report.

2. Observation Status Matrix

S.No	Vulnerability	Severity	Status	Remarks
1	SQL Injection	High	Resolved	Parameterized queries + SQL mitigation middleware
2	Cookies Not Marked as HttpOnly	Low	Resolved	HttpOnly/Secure/SameSite enforced via middleware
3	Clickjacking: CSP frame-ancestors	Low	Resolved	frame-ancestors 'self' set in CSP header
4	Big Redirect Detected	Low	Resolved	Open redirect patched with input validation
5	Missing CSP Header	Low	Resolved	Comprehensive CSP in middleware & .htaccess
6	Missing X-Content-Type-Options	Low	Resolved	X-Content-Type-Options: nosniff header set
7	Cross-Domain JS Inclusion	Low	Resolved	SRI integrity hashes added to all CDN scripts
8	HSTS Header Not Set	Low	Resolved	HSTS with 1-year max-age, preload enabled

3. Detailed Findings & Remediation

3.1 - SQL Injection [HIGH] - RESOLVED

Description: SQL injection exploits vulnerabilities in database queries. Attackers can insert malicious SQL statements through user inputs to manipulate or extract data.

Remediation Applied:

The application uses Laravel's Eloquent ORM with parameterized queries throughout the codebase. Additionally, a dedicated `SqlInjectionMitigation` middleware is registered as a global middleware to detect and block suspicious SQL patterns in all incoming request parameters.

```
File: bootstrap/app.php
$middleware->append(\App\Http\Middleware\SqlInjectionMitigation::class);
```

3.2 - Cookies Not Marked as HttpOnly [LOW] - RESOLVED

Description: When cookies lack the `HttpOnly` flag, they become accessible to client-side JavaScript, making them vulnerable to XSS attacks that can steal session tokens.

Remediation Applied (3 layers):

1. Session Configuration: Laravel session config enforces `http_only: true`, `secure: true`, and `same_site: strict`.
2. Environment: `SESSION_HTTP_ONLY=true`, `SESSION_SECURE_COOKIE=true`, `SESSION_SAME_SITE=strict`, `SESSION_ENCRYPT=true` set in `.env` file.
3. SecureHeaders Middleware: A cookie enforcement method iterates over ALL response cookies and re-creates them with enforced security flags (`HttpOnly`, `Secure`, `SameSite=Strict`).

```
File: app/Http/Middleware/SecureHeaders.php

private function enforceSecureCookies(Response $response): void
{
    foreach ($response->headers->getCookies() as $cookie) {
        $secureCookie = Cookie::create($cookie->getName())
            ->withSecure(true)           // Always Secure
            ->withHttpOnly(true)        // Always HttpOnly
            ->withSameSite('Strict');    // Always SameSite=Strict
        $response->headers->setCookie($secureCookie);
    }
}
```

This catches every cookie - session, XSRF-TOKEN, theme, and third-party cookies - ensuring none are missed.

3.3 - Clickjacking: CSP frame-ancestors Missing [LOW] - RESOLVED

Description: Without the frame-ancestors directive in the CSP header, the application can be embedded in iframes on malicious websites, enabling clickjacking attacks.

Remediation Applied:

The CSP header includes frame-ancestors 'self' which restricts the page from being embedded in any external iframe. The X-Frame-Options: SAMEORIGIN header provides backward compatibility for older browsers.

```
File: app/Http/Middleware/SecureHeaders.php
$response->headers->set('X-Frame-Options', 'SAMEORIGIN');
// CSP includes: frame-ancestors 'self';
```

3.4 - Big Redirect Detected (Open Redirect) [LOW] - RESOLVED

Description: An open redirect vulnerability was identified in the complaint update controller. The redirect_to parameter from user input was passed directly to Laravel's redirect() function without validation, allowing attackers to redirect users to malicious external websites.

Remediation Applied:

The redirect_to parameter is now validated to ensure it is a relative internal path before use. It must start with "/" and must NOT start with "//" (protocol-relative URLs are treated as external by browsers). Invalid values fall through to the safe default route.

```
File: app/Http/Controllers/Admin/ComplaintController.php

if ($request->filled('redirect_to')) {
    $redirectTo = $request->redirect_to;
    // Security: Only allow internal redirects
    if (is_string($redirectTo)
        && str_starts_with($redirectTo, '/')
        && !str_starts_with($redirectTo, '//')) {
        return redirect($redirectTo)
            ->with('success', 'Complaint updated.');
```

Attack Scenario Blocked: An attacker could previously craft ?redirect_to=https://evil.com/phishing to redirect users to a phishing page. This is now prevented.

3.5 - Missing Content-Security-Policy Header [LOW] - RESOLVED

Description: The CSP header instructs browsers to restrict which resources can be loaded, preventing XSS and data injection attacks.

Remediation Applied:

A comprehensive CSP policy was implemented in both the SecureHeaders middleware and the .htaccess file (dual-layer enforcement).

Content-Security-Policy Directives:

```
default-src      'self';
script-src       'self' 'unsafe-inline' https://cdn.jsdelivr.net
                https://cdnjs.cloudflare.com https://cdn.tailwindcss.com;
style-src        'self' 'unsafe-inline' https://cdn.jsdelivr.net
```

```
https://cdnjs.cloudflare.com https://fonts.bunny.net;
font-src      'self' data: https://cdnjs.cloudflare.com https://fonts.bunny.net;
img-src       'self' data: https;;
connect-src   'self';
object-src    'none';
base-uri      'self';
form-action   'self';
frame-src     'none';
frame-ancestors 'self';
```

3.6 - Missing X-Content-Type-Options Header [LOW] - RESOLVED

Description: Without the X-Content-Type-Options: nosniff header, browsers may attempt MIME-type sniffing, potentially executing malicious files as scripts.

Remediation Applied:

The header is set in both the SecureHeaders middleware and .htaccess file.

```
File: app/Http/Middleware/SecureHeaders.php
$response->headers->set('X-Content-Type-Options', 'nosniff');
```

```
File: public/.htaccess
Header set X-Content-Type-Options "nosniff"
```

3.7 - Cross-Domain JavaScript Source File Inclusion [LOW] - RESOLVED

Description: External JavaScript files loaded from CDN domains without Subresource Integrity (SRI) hashes can be tampered with if the CDN is compromised. SRI ensures the browser verifies the file's cryptographic hash before execution.

Remediation Applied:

All external CDN script and stylesheet tags now include integrity (SHA-384 hash) and crossorigin="anonymous" attributes. Unversioned CDN references were pinned to specific versions.

File	CDN Resource	Fix Applied
sidebar.blade.php	chart.js (unversioned)	Pinned to @4.4.7 + SRI hash
dashboard.blade.php	chart.js@3.9.1	SRI integrity hash added
dashboard.blade.php	chartjs-plugin-datalabels@2	Pinned to @2.2.0 + SRI hash
stock/all.blade.php	tailwindcss@2.2.19 CSS	SRI integrity hash added

Example - Before & After:

BEFORE (vulnerable):

```
<script src="https://cdn.jsdelivr.net/npm/chart.js"></script>
```

AFTER (secure - pinned version + SRI hash):

```
<script src="https://cdn.jsdelivr.net/npm/chart.js@4.4.7/dist/chart.umd.min.js"
  integrity="sha384-vsrfeL00Y6KuIYKD..."
  crossorigin="anonymous"></script>
```

3.8 - Strict-Transport-Security Header Not Set [LOW] - RESOLVED

Description: Without HSTS, browsers may allow HTTP connections, making the application vulnerable to protocol downgrade attacks and MITM interception.

Remediation Applied:

The HSTS header is configured with a 1-year max-age, includeSubDomains, and preload directives in both middleware and .htaccess.

```
Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
```

4. Files Modified Summary

#	File Path	Change Description	Issue
1	.env	Added SESSION_ENCRYPT=true	#2
2	app/Http/Middleware/SecureHeaders.php	Cookie enforcement + CSP update	#2, #5
3	app/Http/Controllers/Admin/ComplaintController.php	Open redirect validation	#4
4	resources/views/layouts/sidebar.blade.php	SRI for chart.js (pinned v4.4.7)	#7
5	resources/views/frontend/dashboard.blade.php	SRI for chart.js + datalabels	#7
6	resources/views/frontend/stock/all.blade.php	SRI for tailwindcss	#7
7	public/.htaccess	CSP header sync - added CDN domains	#5, #7

5. Verification & Testing

Issue	Verification Method	Result
#1	All DB queries use Eloquent ORM; SQL injection middleware active globally	Pass
#2	All cookies carry HttpOnly, Secure, SameSite=Strict via middleware	Pass
#3	CSP contains frame-ancestors 'self'; X-Frame-Options set	Pass
#4	redirect_to with external URLs blocked; falls to safe default	Pass
#5	CSP header present in middleware and .htaccess with all CDN domains	Pass
#6	X-Content-Type-Options: nosniff present in all responses	Pass
#7	All CDN scripts have SHA-384 SRI hashes and crossorigin attributes	Pass
#8	HSTS header with max-age=31536000, includeSubDomains, preload	Pass

Conclusion: All 8 security vulnerabilities identified in the audit have been successfully remediated. The CMS now implements defense-in-depth security measures across multiple layers including middleware, configuration, and template-level protections.